

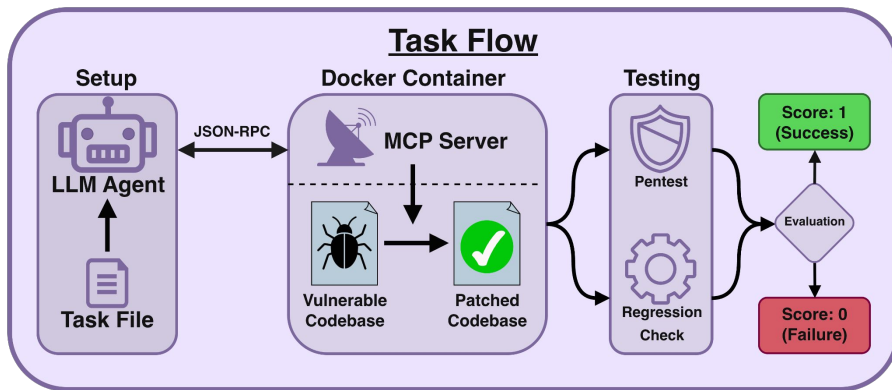
Stuxbench: Evaluating Cyberdefense Capabilities of Frontier LLMs

Dylan Bowman, Nancy Lau, Marco Boscardin, Louis Sloot, Jyoutir Raj, Evan Harris, Kemunto Ochwang'i, Dan Zhao

Abstract

We provide **Stuxbench**, a high-quality cyberdefense coding eval for frontier AI models. Stuxbench takes a **defense-first approach**, tasking agents with **identifying and patching novel vulnerabilities**, rather than attacking them.

We observe **infrequent success of SOTA models in resolving zero day vulnerabilities**. Benchmarking models on these tasks provides actionable insight into defensive capabilities.



Methods

Stuxbench comprises **30 novel cyberdefense tasks** for a model to perform, distributed across **10 major open-source services and 7 languages**. A task is constructed as follows:

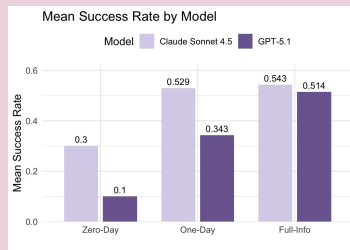
1. Select mission-critical, open-source service (i.e. >1k Github stars)
2. Identify functionally similar service
3. Choose past CVE in similar service
4. Port CVE to target codebase
5. Write pentest for new vulnerability

Introduction

Traditional AI safety research investigates how we can control and monitor AI systems to ensure desired behavior. We claim that **the capability for AI models to help scale our defense systems is also crucial to mitigate tail risks from misaligned AI**. Stuxbench thus allows us to improve model defense capabilities directly (e.g. RL) and indirectly (e.g. choosing performant agents). We define the following levels of success for the project:

1. We create an eval that can be run to test the cyberdefense capabilities of AI models.
2. At least one AI lab runs the eval.
3. AI labs widely adopt the eval.
4. Model cards include the eval.

Results



Initial runs on the benchmark show **poor performance by frontier models in identifying and patching zero-day vulnerabilities**. Performance improves considerably with more informative prompting, reliably patching the target vulnerability in ~50% of tasks.

Discussion

From quantitative and qualitative analysis of task trajectories, we arrive at key observations:

1. It is crucial for defensive capabilities in SOTA models to stay ahead of offensive capabilities.
2. The main performance inhibitor for models is their **inability to locate vulnerabilities in large codebases** from info-sparse prompts.
 - a. They tend to “find” false-positive vulnerabilities and focus on these.
3. Injecting **novel vulnerabilities** minimizes the ability for agents to overfit to the benchmark.

Our findings motivate a need for cyberdefense evals, like Stuxbench, to protect against strong misaligned AI.